FINAL PROJECT BLUE TEAM

Dibimbing Bootcamp

SATRIA PAMUNGKAS

Education

Information Systems
2018 - 2022

Experience

- PT Petro Nusatama Perkasa (2023-2025)
  Infrastructure Engineer/Technician
- Freelance (2021-2023)
  Web3 Tester

Career Interest

- Red Teaming
- OT Cyber Security

PROJECT OVERVIEW

Project ini merupakan final project dari modul blue team bootcamp Dibimbing yang berfokus pada deteksi ancaman dan analisis log keamanan pada infrastruktur server.

Tujuan Project:

- Mengidentifikasi, menganalisis, dan memitigasi aktivitas mencurigakan serta upaya serangan pada sistem server secara real time.

Analysis:

- Melakukan investigasi mendalam terhadap log keamanan (SSH, web server, database) untuk menemukan pola serangan seperti brute force, vulnerability scanning, dan internal misconfiguration.

Result:

- Berhasil mengidentifikasi 5 temuan keamanan, melakukan penilaian risiko menggunakan matrix 5x5 dan MITRE ATT&CK framework, serta memberikan rekomendasi mitigasi untuk system hardening.

Tools:

- Wazuh SIEM
- Linux Server
- MITRE ATT&CK v18

SCOPING & RULES OF ENGAGEMENT (ROE)

Scoping:

- Fokus utama observasi dilakukan pada aplikasi website dan infrastruktur server dibishop.
- Investigasi mendalam terhadap log server untuk mengidentifikasi misconfiguration, upaya serangan, serta indikasi insiden keamanan.
- Menemukan dan mendokumentasikan minimal 4 temuan keamanan yang valid.

Rule of Engagement:

- Website digunakan untuk observasi.
- Server dan log berisikan dari beberapa jenis misconfiguration, attack/attack attempt, maupun indikasi insiden, student harus menemukan minimal 4.
- Membuat rencana analisis yang mencakup prosedur analisis dan pengumpulan evidence.

RENCANA ANALISIS & PROSEDUR:

Identifikasi:

- Memantau dasbor Wazuh untuk mendeteksi anomali atau alert dengan tingkat bahaya tinggi.

Pengumpulan Evidence:

- Melakukan pencarian bukti indikasi misconfiguration, attack/attack attempt, insiden yang berasal dari log (SIEM, database, alert)

Analisis Resiko:

- Menilai dampak temuan menggunakan matrix 5x5 dan melakukan pemetaan menggunakan MITRE ATT&CK Framework.

Dokumentasi:

- Menyusun langkah-langkah mitigasi berdasarkan root cause dari setiap insiden yang ditemukan.

EXECUTIVE SUMMARY

Judul Temuan	Risk Level	Taktik MITRE ATT&CK	Dampak
SSH Auth Misconfiguration	Very High (25)	Initial Access (TA0001) / Credential Access (TA0006)	Penggunaan metode password dan izin login root secara langsung menjadi root cause utama seluruh serangan SSH
SSH Brute Force Attack Analysis	Very High (20)	Credential Access (T1110.001) & Lateral Movement (T1021.004)	Ancaman pada integritas akun user dan mengancam sisi availability server
Web Scanning & Enumeration	Very High (20)	Reconnaissance (TA0043) & Impact (TA0040) Stored Data Manipulation(T1565.001)	Struktur direktori web dapat diketahui & Penyerang berhasil mengedit file OS server
DB Information Disclosure	Moderate (9)	Discovery (TA0007)	Kebocoran skema DB & data pribadi (IP)
Web Server Signature Disclosure	Moderate (8)	Reconnaissance (TA0043) & Gather Victim Host Information Software (T1592.002)	Memudahkan penyerang untuk mengetahui celah keamanan versi aplikasi/service (CVE)

Total Temuan: 5 (3 Very High, 2 Moderate)

SSH BRUTE FORCE ANALYSIS - TARGETED TESTING

Description	Terdeteksi aktivitas recon awal pada 17 Februari 2026 pukul 04:48:16, di mana penyerang mencoba melakukan autentikasi melalui layanan SSH. Serangan ini bersifat tertarget dengan mencoba kombinasi kata sandi pada nama pengguna 'user' dari IP asal Baltimore, US (144.126.192.12). Aktivitas ini terjadi hanya sesaat sebelum serangan Massive Distributed Brute Force terjadi. Karena akun tersebut tidak ada (invalid user), maka setiap percobaan login dari luar negeri ke akun tersebut dipastikan adalah serangan, bukan admin yang lupa password.
Evidence	SIEM Log: • Timestamp (SIEM) 04:46:33 - 04:48:16 (Feb 17, 2026) • Source IP / Geo: 144.126.192.12 (Baltimore, United States) • Target User: user (Invalid) • Wazuh AlertRule ID 5712 (Level 10) - SSHD Brute Force • Event Frequency: 8 percobaan dalam waktu singkat Log: Feb 17 04:48:16 srv974671 sshd[38816]: Failed password for invalid user user from 144.126.192.12 port 58444 ssh2
Risk Assessment	Mitre ATT&CK: • TA0006 (Credential Access), T1110 (Brute Force) Dampak: • Penyerang mampu mengakses sistem secara tidak sah • Penyerang mampu merubah konfigurasi sistem
Mitigation	• Blokir IP Address • Terapkan SSH Key Based Authentication • Terapkan MFA untuk akses SSH

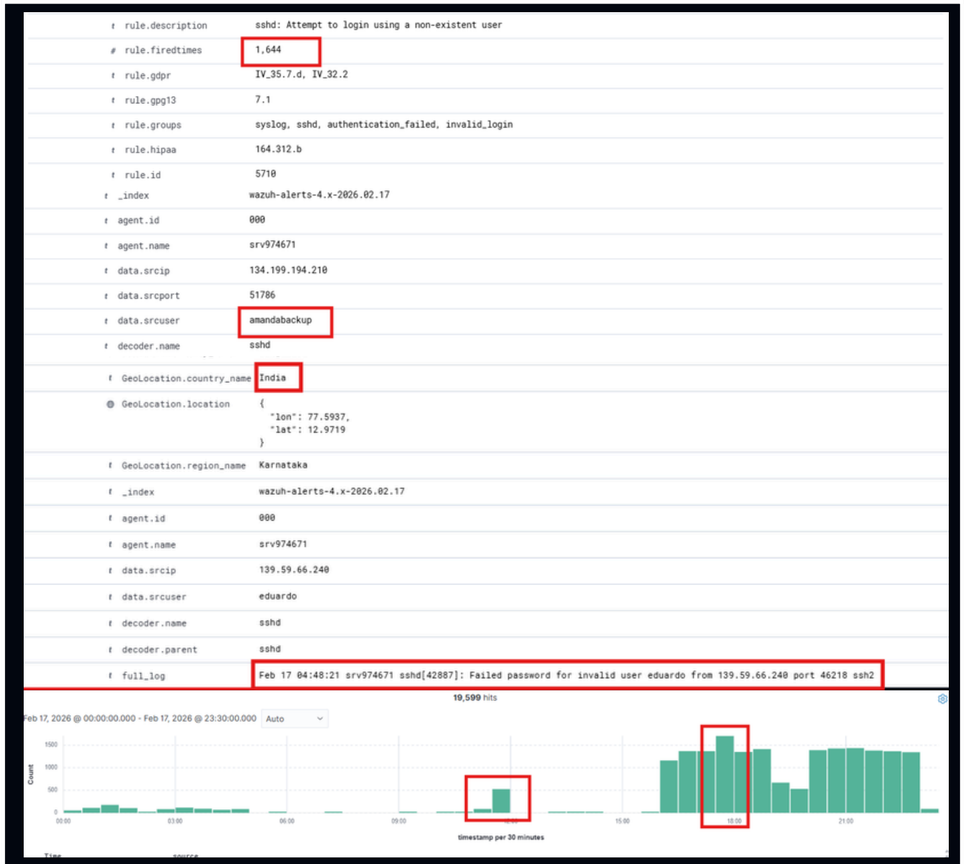
POC

data.srcip	144.126.192.12
data.srcuser	user
decoder.name	sshd
decoder.parent	sshd
full_log	Feb 16 21:48:16 srv974671 sshd[38816]: Failed password for invalid user user from 144.126.192.12 port 58444 ssh2
id	1771278498.857701
previous_output	Feb 16 21:48:14 srv974671 sshd[38816]: Invalid user user from 144.126.192.12 port 58444 Feb 16 21:47:43 srv974671 sshd[38813]: Failed password for invalid user user from 144.126.192.12 port 53356 ssh2 Feb 16 21:47:40 srv974671 sshd[38813]: Invalid user user from 144.126.192.12 port 53356 Feb 16 21:47:08 srv974671 sshd[38810]: Failed password for invalid user user from 144.126.192.12 port 56276 ssh2 Feb 16 21:47:07 srv974671 sshd[38810]: Invalid user user from 144.126.192.12 port 56276 Feb 16 21:46:35 srv974671 sshd[38807]: Failed password for invalid user admin from 144.126.192.12 port 54104 ssh2 Feb 16 21:46:33 srv974671 sshd[38807]: Invalid user admin from 144.126.192.12 port 54104
rule.description	sshd: brute force trying to get access to the system. Non existent user.
GeoLocation.city_name	Baltimore
GeoLocation.country_name	United States
rule.id	5712
rule.level	10
rule.mail	false
rule.mitre.id	T1110
rule.mitre.tactic	Credential Access
rule.mitre.technique	Brute Force

SSH BRUTE FORCE ANALYSIS - MASSIVE

Description	Terdeteksi rangkaian serangan Distributed Brute Force masif lintas negara pada 17 Februari 2026. Serangan bergeser dari pola satu IP (Slide sebelumnya) menjadi penggunaan banyak IP unik untuk menghindari deteksi pada rule IP tunggal. Aktivitas bersifat repetitif, dimulai dari wilayah Asia (India) pada siang hari, berlanjut ke Amerika Utara (Kanada & USA) hingga malam hari.
Evidence	Pattern (SIEM Event Log): • Wazuh Rule ID: 5710 – Attempt to login using a non-existent user Volume Serangan: • Pukul 11:41: IP asal India (139.59.66.240) melakukan 113 percobaan. • Pukul 17:59: IP asal Kanada (134.199.194.210) melakukan 1.644 percobaan pada akun amandabackup. • Pukul 22:55 - 23:29: Lonjakan serangan dari US menargetkan akun root/PAM dan odoo. Log Sample: Feb 17 10:59:58 srv974671 sshd[52027]: Invalid user amandabackup from 134.199.194.210
Risk Assessment	Mitre ATT&CK: Credential Access (T1110.001) & Lateral Movement (T1021.004). Dampak: • Risiko pengambil alihan akun pengguna, • Penurunan performa server akibat beban proses otentikasi masif • Potensi penuhnya kapasitas penyimpanan log sistem.
Mitigation	• Implementasi Geo-Blocking untuk membatasi akses dari negara yang tidak relevan • Terapkan SSH Key Based Authentication • Terapkan Active Response (Wazuh) atau Fail2Ban untuk pemblokiran IP otomatis.

POC



MATRIX 5X5

Impact (Y)/ Likelihood (X)	Insignificant(1)	Minor(2)	Moderate(3)	**Major(4)**	Critical(5)
Very Likely (5)	Low (5)	Moderate (10)	High (15)	**Very High (20)**	Very High (25)
Likely (4)	Low (4)	Moderate (8)	High (12)	High (16)	Very High (20)
Possible (3)	Very Low (3)	Low (6)	Moderate (9)	High (12)	High (15)
Unlikely (2)	Very Low (2)	Low (4)	Low (6)	Moderate (8)	Moderate (10)
Rare (1)	Very Low (1)	Very Low (2)	Very Low (3)	Low (4)	Low (5)

Total Skor Risk:

- Impact (4) x Likelihood (5) = 20.

Justifikasi:

- Perkembangan serangan dari pola targeted menjadi massive distributed meningkatkan peluang keberhasilan compromise akun sistem. Dampak serangan mencakup potensi pengambil alihan kontrol server, kebocoran data, serta gangguan stabilitas layanan akibat beban proses otentikasi yang ekstrem.

SSH AUTH MISCONFIGURATION (ROOT CAUSE)

Description	Teridentifikasi celah keamanan pada konfigurasi layanan SSH di mana PasswordAuthentication dan PermitRootLogin masih diaktifkan. Hal ini merupakan akar masalah (root cause) yang memungkinkan penyerang melakukan brute force langsung terhadap akun administratif tertinggi (root).
Evidence	Command: • grep -E "^PasswordAuthentication|^PermitRootLogin" /etc/ssh/sshd_config Result: • PermitRootLogin yes • PasswordAuthentication yes
Risk Assessment	Mitre ATT&CK: • Initial Access (TA0001) • Credential Access (TA0006) Brute Force & Password Guessing (T1110.001) Dampak: • Jika password Root berhasil ditebak maka penyerang mampu menguasai seluruh sistem • Penyerang mampu melakukan lateral movement ke server lain • Potensi terjadinya pencurian dan kebocoran data sensitif
Mitigation	• Ubah PasswordAuthentication yes menjadi PasswordAuthentication no di /etc/ssh/sshd_config • Batasi akses SSH hanya melalui VPN atau IP Whitelisting • Implement Fail2Ban untuk memblokir IP secara otomatis jika gagal login beberapa kali

POC

```
root@srv974671:~# sshd -T | grep -E "passwordauthentication|permitrootlogin"
permitrootlogin yes
passwordauthentication yes
root@srv974671:~#
```

```
/var/log/auth.log.1:2026-02-21T21:06:17.332736+00:00 srv974671 sshd[135000]: Failed password for root from 137.184.203.81 port 50476 ssh2
/var/log/auth.log.1:2026-02-21T21:07:16.875736+00:00 srv974671 sshd[135004]: Failed password for root from 137.184.203.81 port 46196 ssh2
/var/log/auth.log.1:2026-02-21T21:08:13.987554+00:00 srv974671 sshd[135007]: Failed password for root from 137.184.203.81 port 41748 ssh2
/var/log/auth.log.1:2026-02-21T21:09:12.030066+00:00 srv974671 sshd[135012]: Failed password for root from 137.184.203.81 port 48612 ssh2
/var/log/auth.log.1:2026-02-21T21:10:07.420838+00:00 srv974671 sshd[135070]: Failed password for root from 137.184.203.81 port 58070 ssh2
/var/log/auth.log.1:2026-02-21T21:11:01.863547+00:00 srv974671 sshd[135088]: Failed password for root from 137.184.203.81 port 58486 ssh2
/var/log/auth.log.1:2026-02-21T21:11:55.518230+00:00 srv974671 sshd[135091]: Failed password for root from 137.184.203.81 port 45210 ssh2
/var/log/auth.log.1:2026-02-21T21:12:50.647795+00:00 srv974671 sshd[135095]: Failed password for root from 137.184.203.81 port 59234 ssh2
/var/log/auth.log.1:2026-02-21T21:13:47.832945+00:00 srv974671 sshd[135098]: Failed password for root from 137.184.203.81 port 40264 ssh2
/var/log/auth.log.1:2026-02-21T21:14:49.631272+00:00 srv974671 sshd[135102]: Failed password for root from 137.184.203.81 port 45170 ssh2
/var/log/auth.log.1:2026-02-21T21:15:52.624012+00:00 srv974671 sshd[135108]: Failed password for root from 137.184.203.81 port 45756 ssh2
/var/log/auth.log.1:2026-02-21T21:16:56.393232+00:00 srv974671 sshd[135125]: Failed password for root from 137.184.203.81 port 49036 ssh2
/var/log/auth.log.1:2026-02-21T21:17:53.780790+00:00 srv974671 sshd[135132]: Failed password for root from 137.184.203.81 port 46556 ssh2
/var/log/auth.log.1:2026-02-21T21:18:49.311100+00:00 srv974671 sshd[135135]: Failed password for root from 137.184.203.81 port 52886 ssh2
/var/log/auth.log.1:2026-02-21T21:19:45.805631+00:00 srv974671 sshd[135138]: Failed password for root from 137.184.203.81 port 41266 ssh2
root@srv974671:~#
```

MATRIX 5X5

Impact (Y)/ Likelihood (X)	Insignificant(1)	Minor(2)	Moderate(3)	Major(4)	**Critical(5)**
Very Likely (5)	Low (5)	Moderate (10)	High (15)	Very High (20)	**Very High (25)**
Likely (4)	Low (4)	Moderate (8)	High (12)	High (16)	Very High (20)
Possible (3)	Very Low (3)	Low (6)	Moderate (9)	High (12)	High (15)
Unlikely (2)	Very Low (2)	Low (4)	Low (6)	Moderate (8)	Moderate (10)
Rare (1)	Very Low (1)	Very Low (2)	Very Low (3)	Low (4)	Low (5)

Total Skor Risk:

- Impact (5) x Likelihood (5) = 25.

Justifikasi:

- Temuan ini bukanlah bentuk serangan eksternal namun merupakan konfigurasi internal yang salah yang merupakan akar dari serangan brute force yang terjadi. Jika serangan brute force berhasil dampaknya server akan full compromise dan beresiko tinggi terjadinya kebocoran data.

SSH ATTACK CORRELATION FINDING 1 & 2

Correlation:

- Penyerang mencoba melihat respon server dengan satu IP untuk mengukur sistem keamanan.
- Setelah melihat celah, serangan ditingkatkan menggunakan banyak IP dari berbagai negara agar tidak mudah diblokir.
- Serangan ini berbahaya karena konfigurasi PermitRootLogin masih aktif.
- Mendapatkan akses Root dan melakukan eksfiltrasi data atau kontrol penuh pada server Dibishop.

DATABASE INFORMATION DISCLOSURE

Description	Aktifnya fitur general query log pada MySQL yang mencatat seluruh aktivitas transaksi aplikasi secara plain text. Serta kolom tabel pada database juga tercatat pada log database. File log yang ditemukan dapat diakses oleh user tanpa hak akses khusus (sudo), sehingga mempermudah pengguna mana pun di dalam sistem untuk mengintip data sensitif.
Evidence	Log Source: /var/lib/mysql/srv974671.log 2026-02-26T02:25:48.849091Z 180 Connect dibimbing-shop@localhost 2026-02-26T02:25:48.892238Z 181 Query SELECT * FROM cart WHERE ip_add='36.69.81.131' 2026-02-26T02:25:48.904979Z 181 Query SELECT * FROM products ORDER BY 1 DESC
Risk Assessment	Mitre ATT&CK: • Discovery (TA0007) System Information Discovery (T1082) Dampak: • Penyerang mampu mengetahui struktur tabel database • Kebocoran data pribadi yang melanggar UU PDP • Penyerang dapat mengambil informasi sensitif tanpa harus melakukan privilege escalation
Mitigation	• Nonaktifkan fitur general query log pada lingkungan produksi • Batasi izin akses file log hanya untuk user administratif • Terapkan hashing/masking pada data pribadi pengguna (IP address)

POC

```
Linux srv974671 6.8.0-90-generic #91-Ubuntu SMP PREEMPT_DYNAMIC Tue Nov 18 14:14:30 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
root@srv974671:~# tail -n 50 /var/lib/mysql/srv974671.log
2026-02-25T12:56:12.733972Z       171 Query     select * from products where product_id='10'
2026-02-25T12:56:12.735230Z       171 Query     select * from products order by rand() LIMIT 0,3
2026-02-25T12:56:12.735769Z       171 Query     select * from manufacturers where manufacturer_id='15'
2026-02-25T12:56:12.736081Z       171 Query     select * from manufacturers where manufacturer_id='12'
2026-02-25T12:56:12.736365Z       171 Query     select * from manufacturers where manufacturer_id='11'
2026-02-25T12:56:12.736855Z       171 Quit
```

```
2026-02-26T00:00:33.517898Z       179 Quit
2026-02-26T02:25:48.849091Z       180 Connect   dibimbing-shop@localhost on dibimbing-shop using Socket
2026-02-26T02:25:48.882411Z       181 Connect   dibimbing-shop@localhost on dibimbing-shop using Socket
2026-02-26T02:25:48.885965Z       180 Quit
2026-02-26T02:25:48.892238Z       181 Query     SELECT * FROM cart WHERE ip_add='36.69.81.131'
2026-02-26T02:25:48.904979Z       181 Query     SELECT * FROM products ORDER BY 1 DESC LIMIT 0, 8
2026-02-26T02:25:48.909151Z       181 Query     SELECT * FROM manufacturers WHERE manufacturer_id='15'
2026-02-26T02:25:48.912416Z       181 Query     SELECT * FROM manufacturers WHERE manufacturer_id='12'
2026-02-26T02:25:48.912971Z       181 Query     SELECT * FROM manufacturers WHERE manufacturer_id='11'
2026-02-26T02:25:48.917807Z       181 Quit
root@srv974671:~#
```

MATRIX 5X5

Impact (Y)/ Likelihood (X)	Insignificant(1)	Minor(2)	**Moderate(3)**	Major(4)	Critical(5)
Very Likely (5)	Low (5)	Moderate (10)	High (15)	Very High (20)	Very High (25)
Likely (4)	Low (4)	Moderate (8)	High (12)	High (16)	Very High (20)
Possible (3)	Very Low (3)	Low (6)	**Moderate (9)**	High (12)	High (15)
Unlikely (2)	Very Low (2)	Low (4)	Low (6)	Moderate (8)	Moderate (10)
Rare (1)	Very Low (1)	Very Low (2)	Very Low (3)	Low (4)	Low (5)

Total Skor Risk:

- Impact (3) x Likelihood (3) = 9.

Justifikasi:

- Temuan ini merupakan kesalahan konfigurasi internal yang seharusnya digunakan pada tahap development namun tetap ada sampai tahap produksi. Penyerang mampu memetakan attack surface berdasarkan informasi yang didapat dari log server yang verbose. Jika penyerang berhasil memasuki server, penyerang langsung bisa mendapatkan data log tanpa harus melakukan privilege escalation.

WEB SCANNING & ENUMERATION

Description	Terdeteksi aktivitas recon dan enumeration tingkat lanjut pada service apache. Penyerang menggunakan IP 172.232.232.48 dengan teknik automated directory fuzzing (Wazuh Rule 31101) pada path /metasys/. Aktivitas ini berkorelasi dengan terdeteksinya perubahan integritas pada file biner sistem /etc/ld.so.cache pada tanggal yang sama, yang menunjukkan upaya penyerang untuk memodifikasi library sistem setelah fase recon.
Evidence	• Source & Target: 172.232.232.48 > /var/log/apache2/access.log. • Pattern: Directory Enumeration via GET request ke path /metasys/. • rule.firedtimes: 57 (automated fuzzing dalam waktu singkat). • Wazuh Rule: 31101 - Web server 400 error code. • System Impact (Korelasi): Terdeteksi perubahan integritas file /etc/ld.so.cache (Rule 550) pada periode waktu yang sama (19 Feb).
Risk Assessment	Mitre ATT&CK: • Reconnaissance (TA0043). • Impact (TA0040) / Stored Data Manipulation(T1565.001) Dampak: • Request sebanyak 57x dalam satu waktu memenuhi log • Penyerang berhasil mengakses file OS Linux yang sensitif. • Perubahan pada /etc/ld.so.cache mengindikasikan upaya untuk melakukan manipulasi library sistem, yang dapat menyebabkan privilege escalation, persistence, atau kontrol penuh atas server Dibishop.
Mitigation	• Masukkan IP penyerang dalam blacklist • Implementasikan WAF (Web Application Firewall) • Konfigurasi rate limiting

POC

t data.protocol	GET
t data.srcip	172.232.232.48
t data.url	/metasys/com/jci/metasys/MetasysProperties.properties
t decoder.name	web-accesslog
t full_log	172.232.232.48 - - [19/Feb/2026:00:33:29 +0000] "GET /metasys/com/jci/metasys/MetasysProperties.properties HTTP/1.1" 404 463 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64) AppleWebKit/537.36 (KHTML"
t id	1771461210.37907
t input.type	log
t location	/var/log/apache2/access.log
t manager.name	srv974671
t rule.description	Web server 400 error code.
# rule.firedtimes	57
t rule.gdpr	IV_35.7.d
t rule.groups	web, accesslog, attack
t rule.id	31101
# rule.level	5

t full_log	File '/etc/ld.so.cache' modified Mode: scheduled Changed attributes: inode,mtime Old modification time was: '1771308199', now it is '1771483309' Old inode was: '4753', now it is '6328'
t id	1771524976.737163
t input.type	log
t location	syscheck
t manager.name	srv974671
t rule.description	Integrity checksum changed.

syscheck.mtime_after	Feb 19, 2026 @ 13:41:49.000
syscheck.mtime_before	Feb 17, 2026 @ 13:03:19.000
t syscheck.path	/etc/ld.so.cache

MATRIX 5X5

Impact (Y)/ Likelihood (X)	Insignificant(1)	Minor(2)	Moderate(3)	Major(4)	**Critical(5)**
Very Likely (5)	Low (5)	Moderate (10)	High (15)	Very High (20)	Very High (25)
Likely (4)	Low (4)	Moderate (8)	High (12)	High (16)	**Very High (20)**
Possible (3)	Very Low (3)	Low (6)	Moderate (9)	High (12)	High (15)
Unlikely (2)	Very Low (2)	Low (4)	Low (6)	Moderate (8)	Moderate (10)
Rare (1)	Very Low (1)	Very Low (2)	Very Low (3)	Low (4)	Low (5)

Total Skor Risk:

- Impact (5) x Likelihood (4) = 20.

Justifikasi:

- Temuan ini melibatkan aktivitas directory fuzzing sebanyak 57 kali yang diikuti dengan modifikasi tidak sah pada file sistem /etc/ld.so.cache. Perubahan atribut file oleh akun root menunjukkan bahwa penyerang telah mencapai tahap manipulasi data sistem untuk tujuan Persistence atau Defense Evasion. Dampaknya sangat besar karena dapat menyebabkan kompromi total pada integritas server dan memungkinkan penyerang memasang backdoor.

WEB SERVER SIGNATURE DISCLOSURE

Description	Konfigurasi HTTP Response Header membocorkan versi spesifik service Apache/2.4.58 (Ubuntu).
Evidence	Command: • curl -I http://localhost Hasil: • HTTP/1.1 200 OK • Date: Fri, 06 Mar 2026 12:48:59 GMT • Server: Apache/2.4.58 (Ubuntu) • Last-Modified: Tue, 26 Aug 2025 02:29:19 GMT
Risk Assessment	Mitre ATT&CK: • Reconnaissance (TA0043) Gather Victim Host Information Software (T1592.002) Dampak: • Memudahkan penyerang untuk mencari exploit yang spesifik (CVE) sesuai dengan versi Apache yang terdeteksi. • Security by Obscurity Violation, server mengharuskan penyembunyian informasi teknis dari publik untuk memperlambat analisis penyerang.
Mitigation	• Konfigurasi ServerTokens Prod dan ServerSignature off pada Apache. agar hanya merespon "Apache" tanpa versi dan menghapus baris informasi server yang biasanya muncul di bagian bawah halaman error.

POC

```
analyst@srv974671:~$ curl -I http://localhost
HTTP/1.1 200 OK
Date: Fri, 06 Mar 2026 12:48:59 GMT
Server: Apache/2.4.58 (Ubuntu)
Last-Modified: Tue, 26 Aug 2025 02:29:19 GMT
ETag: "29af-63d3b70712158"
Accept-Ranges: bytes
Content-Length: 10671
Vary: Accept-Encoding
Content-Type: text/html
```

MATRIX 5X5

Impact (Y)/ Likelihood (X)	Insignificant(1)	**Minor(2)**	Moderate(3)	Major(4)	Critical(5)
Very Likely (5)	Low (5)	Moderate (10)	High (15)	Very High (20)	Very High (25)
Likely (4)	Low (4)	**Moderate (8)**	High (12)	High (16)	Very High (20)
Possible (3)	Very Low (3)	Low (6)	Moderate (9)	High (12)	High (15)
Unlikely (2)	Very Low (2)	Low (4)	Low (6)	Moderate (8)	Moderate (10)
Rare (1)	Very Low (1)	Very Low (2)	Very Low (3)	Low (4)	Low (5)

Total Skor Risk:

- Impact (2) x Likelihood (4) = 8.

Justifikasi:

- informasi versi Apache 2.4.58 terpapar secara publik dalam HTTP Header sehingga sangat mudah ditemukan melalui automated scanning. Namun, karena versi ini sudah di patched celah kritis seperti CVE-2023-44487, Penyerang tidak dapat melakukan eksploitasi secara mudah dan hanya memperoleh data intelijen awal tanpa akses langsung ke sistem.

CONCLUSION & SUGGESTION

Conclusion:

- Wazuh mengidentifikasi 1.644 percobaan brute force dan directory fuzzing secara masif.
- Penyerang berhasil memodifikasi file sistem /etc/ld.so.cache akibat miskonfigurasi PermitRootLogin.
- Konfigurasi verbose database dan web server signature (Apache 2.4.58) memfasilitasi tahap Discovery penyerang.
- Konfigurasi development di lingkungan produksi memperluas attack surface dan melanggar regulasi UU PDP.

Suggestion:

- Nonaktifkan PermitRootLogin dan beralih ke key based authentication.
- Restore file /etc/ld.so.cache dari backup bersih untuk menghapus potensi malicious code.
- Ubah log ke Error Only dan terapkan ServerTokens Prod pada Apache.
- Optimalkan Wazuh FIM ke mode real-time untuk pengawasan direktori kritis (/etc, /bin, /sbin).
- Terapkan prinsip least privilege dan blokir IP penyerang secara otomatis menggunakan Active Response atau Fail2Ban.

TERIMA KASIH

DIBUAT OLEH SATRIA PAMUNGKAS